

Audit and Accountability (3.3) Family

Security Requirements and the Technologies That Implement Them

A practitioner reference for Defense Industrial Base contractors · Family 3 of 14 in a 14-part series on the NIST SP 800-171 families · Prepared July 2026

Overview of the Audit and Accountability Family

Audit and Accountability (3.3) answers a single question: when something happens in the environment, can you determine **what** happened, **when**, on **which** system, and - critically - **which individual user** did it? The family requires that audit records be generated, retained, reviewed on a defined cadence, correlated for investigation, protected from tampering, and time-stamped against an authoritative clock so events from different systems can be sequenced.

The family contains **9 security requirements** - **2 Basic** (from FIPS 200) and **7 Derived** (from NIST SP 800-53). Two requirements - 3.3.1 (create and retain audit logs) and 3.3.5 (correlate review, analysis, and reporting) - carry the maximum **5-point** weight, one (3.3.2) is weighted at 3 points, and the family is dense with process evidence: assessors routinely ask not just for the SIEM dashboard but for **records of humans reviewing it**. A logging pipeline that no one looks at fails 3.3.3 and 3.3.5 regardless of how much it collects. This is **Family 3 of 14** in a planned series covering all fourteen 800-171 families.

Which revision applies? This guide covers **NIST SP 800-171 Revision 2**, which is the baseline the DoD's CMMC program and DFARS 252.204-7012 currently require. In May 2024 NIST published **Revision 3**, which rennumbers this family to 03.03 and restructures it into eight requirements (individual user accountability and the logged-event review fold into the event-logging and audit-record-content requirements, and limiting audit management merges into protection of audit information), and introduces organization-defined event types and review frequencies. Revision 3 has **not** been adopted for CMMC as of this writing - continue to assess against Revision 2 until the DoD formally transitions, and treat Revision 3 as forward-looking.

Requirement wording below is **summarized for readability**. The controlling text is the official publication, **NIST SP 800-171 Rev 2** (security requirements) and **NIST SP 800-171A** (assessment objectives); consult them for exact language. SPRS point values are per the **DoD Assessment Methodology** (NIST SP 800-171 DoD Assessment Methodology, Rev 2).

The 9 Audit and Accountability Requirements and Expected Evidence

The evidence column lists the artifacts an assessor typically expects; most controls need **both** a written policy and a technical artifact. The figure under each control ID is its **SPRS point value** (5, 3, or 1) - the score deducted if the control is not met.

NIST SP 800-171 Rev 2 Audit and Accountability (3.3) requirements, SPRS weight, and expected evidence.

Control	Security Requirement	Evidence / Artifacts an Assessor Expects
3.3.1 5 pts	Create and retain system audit logs and records to the extent needed to enable the monitoring, analysis, investigation, and reporting of unlawful or unauthorized system activity.	Audit and accountability policy defining logged event types and retention period; audit policy configuration exports (advanced audit policy, auditd rules); SIEM data-source inventory; retention configuration and proof logs actually span the stated period
3.3.2 3 pts	Ensure that the actions of individual system users can be uniquely traced to those users, so they can be held accountable for their actions.	Unique-account policy (no shared accounts, or documented compensating controls); sample audit records showing individual usernames; service-account inventory; PAM session-attribution records for shared/root access
3.3.3 1 pt	Review and update logged events.	Documented list of logged event types with rationale; periodic review records (meeting notes, tickets) showing the event list was reassessed and updated; change history of audit policy
3.3.4 1 pt	Alert in the event of an audit logging process failure.	SIEM health-monitoring / heartbeat alert rules for silent log sources, agent failures, and storage-full conditions; sample alert notifications; response procedure for logging failures
3.3.5 5 pts	Correlate audit record review, analysis, and reporting processes for investigation and response to indications of unlawful, unauthorized, suspicious, or unusual activity.	SIEM correlation / analytics rules export; alert-triage workflow and records (tickets, dispositions); documented link from audit review into the incident-response process
3.3.6 1 pt	Provide audit record reduction and report generation to support on-demand analysis and reporting.	SIEM saved searches, dashboards, and scheduled reports; sample generated report; demonstration of filtering large volumes of records to a relevant subset on demand
3.3.7 1 pt	Provide a system capability that compares and synchronizes internal system clocks with an authoritative source to generate time stamps for audit records.	NTP / time-service configuration exports (<code>w32tm</code> , <code>chrony</code>) showing the authoritative source and hierarchy; domain time architecture description; sample records showing consistent timestamps

Control	Security Requirement	Evidence / Artifacts an Assessor Expects
3.3.8 1 pt	Protect audit information and audit logging tools from unauthorized access, modification, and deletion.	SIEM RBAC configuration; immutability / WORM or retention-lock settings on log storage; ACLs restricting log files and audit tools; evidence ordinary admins cannot purge logs
3.3.9 1 pt	Limit management of audit logging functionality to a subset of privileged users.	Named list of users authorized to manage audit logging; SIEM admin-role membership export; GPO delegation showing who can modify audit policy or clear event logs

2 Basic requirements (3.3.1-3.3.2) and 7 Derived requirements (3.3.3-3.3.9). Under CMMC scoring rules (32 CFR 170.21) only requirements weighted at 1 point may be placed on a POA&M at assessment (with a narrow exception for 3.13.11) - so the six 1-point requirements (3.3.3, 3.3.4, 3.3.6, 3.3.7, 3.3.8, and 3.3.9) are POA&M-eligible, while the two 5-point requirements (3.3.1, 3.3.5) and the 3-point 3.3.2 must be implemented before the assessment.

Two 5-point requirements. 3.3.1 (create and retain audit logs) and 3.3.5 (correlate audit review, analysis, and reporting) each carry a 5-point SPRS deduction, and under the CMMC Level 2 rules (32 CFR 170.21) a POA&M at assessment time may only contain 1-point requirements (with a single 3-point exception for 3.13.11). A 5-point requirement **cannot remain on a POA&M** - both, together with the 3-point 3.3.2, must be fully implemented before the assessment, not planned. A collection pipeline and a working review process are the family's core; stand them up first.

Implementing Technologies and How to Configure Them

The systems below are the common building blocks for the family. The SIEM is the center of gravity - it collects, correlates, alerts, reports, retains, and access-controls the audit trail - but it is only as good as the audit policies on the endpoints feeding it and the humans reviewing its output.

SIEM Selection (Microsoft Sentinel, Splunk, Elastic Security, Wazuh)

- **Microsoft Sentinel** - the default for M365/Azure-centric contractors; available in Azure Government for GCC High-aligned environments. Native connectors for Entra ID sign-in/audit logs, Office 365, Defender, and Windows via the Azure Monitor Agent; analytics rules in KQL; log retention configured per Log Analytics workspace. (3.3.1, 3.3.5)
- **Splunk Enterprise / Splunk Cloud** - mature on-premises or cloud option with Enterprise Security for correlation; index-level retention and role-based access controls map cleanly to 3.3.8/3.3.9. (3.3.1, 3.3.5, 3.3.8)
- **Elastic Security** - self-managed or Elastic Cloud; detection rules, index lifecycle management (ILM) for retention tiers, and document-level security. (3.3.1, 3.3.6)

- **Wazuh** - open-source SIEM/XDR (agent-based, built on OpenSearch) popular with budget-constrained contractors; provides file-integrity monitoring, rule-based alerting, and compliance dashboards at the cost of more self-managed engineering. (3.3.1, 3.3.4, 3.3.5)
- Whichever platform: maintain a **data-source inventory** mapping every in-scope system (domain controllers, servers, endpoints, firewalls, cloud audit logs, VPN, PAM) to its connector, and treat any in-scope system not forwarding logs as a finding-in-waiting. (3.3.1)

Windows Advanced Audit Policy and Sysmon

- Deploy **Advanced Audit Policy Configuration** via GPO or Intune rather than legacy audit categories: at minimum Logon/Logoff, Account Logon (Kerberos and credential validation), Account Management, Security Group Management, Policy Change, Privilege Use, and Process Creation (Event ID 4688) with `ProcessCreationIncludeCmdLine_Enabled` for command-line capture. (3.3.1, 3.3.2)
- Add **Sysmon** with a curated configuration (SwiftOnSecurity or Olaf Hartong's modular config) for high-fidelity process, network-connection, and image-load telemetry that native auditing lacks; forward Sysmon's operational channel to the SIEM. (3.3.1, 3.3.5)
- Enable "Audit: Force audit policy subcategory settings to override audit policy category settings" so advanced policy reliably wins, and verify effective policy with `auditpol /get /category:*`. (3.3.1)
- Size the Security event log generously (1 GB or more) and set retention to overwrite-as-needed *with forwarding in place* - local logs are a buffer, not the system of record. (3.3.1, 3.3.8)
- For Linux hosts, deploy **auditd** with a baseline ruleset (the DISA STIG or Neo23x0 rules) plus syslog forwarding; for macOS, use the unified log and an MDM-deployed forwarder. (3.3.1)

Log Collection and Forwarding

- Use the platform-native agent - Azure Monitor Agent (Sentinel), Splunk Universal Forwarder, Elastic Agent, or the Wazuh agent - deployed via GPO/Intune so coverage is enforced, not opt-in. (3.3.1)
- Collect network-device and appliance logs via syslog (TLS where supported) to a collector; do not leave firewall, VPN, and wireless-controller logs stranded on the device. (3.3.1)
- Pull cloud-native audit trails - Entra ID sign-in and audit logs, the M365 Unified Audit Log, AWS CloudTrail, Azure Activity Log - into the SIEM through first-party connectors. (3.3.1, 3.3.2)

Per-User Accountability (3.3.2)

- Enforce unique named accounts for every user; prohibit shared accounts in policy and hunt for them in the directory. Where a shared or built-in account is unavoidable (root, a lab

instrument login), front it with PAM check-out so use is attributed to an individual. (3.3.2)

- Inventory service accounts, document their owners, and alert on interactive logons by service accounts - an interactive service-account session is an unattributable session. (3.3.2)
- Require administrators to use named admin accounts (`jsmith-adm`), never a shared "Administrator"; capture privileged sessions through a bastion or PAM recording so privileged actions trace to a person. (3.3.2)

Time Synchronization (3.3.7)

- Windows domains: point the PDC emulator at an authoritative external source (NIST time servers such as `time.nist.gov` , the community NTP Pool (`pool.ntp.org`), or a GPS appliance) via `w32tm /config /manualpeerlist:...` ; all domain members then sync through the domain hierarchy by default. (3.3.7)
- Linux and network devices: configure **chrony** or **ntpd** against the same source set; point firewalls, switches, and hypervisors at the same internal tier so every log source shares one clock. (3.3.7)
- Normalize SIEM ingestion to UTC and verify with a cross-system query that timestamps agree; a few minutes of drift can wreck event correlation and the credibility of an investigation timeline. (3.3.5, 3.3.7)

Log Retention

- Set a retention period in policy and configure the SIEM to honor it. Rev 2 does not name a number, but **one year** is the common DIB benchmark (with 90 days hot/searchable), aligning with DFARS 252.204-7012's preservation expectations for incident data; media covered by an incident report must be preserved for at least 90 days from reporting. (3.3.1)
- Use tiering to control cost: Sentinel long-term retention / archive tiers, Splunk index rollover to cold storage, Elastic ILM to searchable snapshots, or export to immutable object storage (Azure immutable blobs, S3 Object Lock). (3.3.1, 3.3.8)
- Prove it: retention *settings* plus a query returning records at the far edge of the window is the evidence pair assessors want. (3.3.1)

Audit Review Workflow and Alert Triage (3.3.3, 3.3.5)

- Define the review cadence in procedure - e.g., daily triage of high-severity alerts, weekly review of authentication and privileged-activity dashboards, monthly review of the logged-event list - and **generate records**: a ticket, a signed checklist, or a short log-review note per session. (3.3.3, 3.3.5)
- Build correlation content, not just collection: impossible-travel and anomalous sign-in rules, privileged-group changes, mass file access on CUI shares, log-source-silent detections, and

lockout storms. Sentinel analytics rules, Splunk ES correlation searches, Elastic detection rules, and Wazuh rulesets all export as reviewable artifacts. (3.3.5)

- Route alerts into a ticketing system (Jira, ServiceNow, the SIEM's own case management) so every alert has a recorded disposition - triaged, escalated to incident response, or closed as benign with rationale. (3.3.5)
- Revisit the logged-event list at least annually and after incidents or architecture changes; record the review even when the outcome is "no change." That record *is* the 3.3.3 evidence. (3.3.3)
- Small teams without 24x7 staff commonly meet this family through a managed SOC / MDR service (e.g., Arctic Wolf, Huntress, or an MSSP running Sentinel) - keep the service's review and escalation reports as evidence, and document the shared responsibility in the SSP.

Audit Logging Failure Alerting (3.3.4)

- Alert on silent log sources: Sentinel's health monitoring and heartbeat/watchlist queries, Splunk's `metadata` -based lag searches, Elastic agent health, or Wazuh's agent-disconnect events. Set per-source thresholds tuned to normal reporting intervals. (3.3.4)
- Alert on the infrastructure, too: ingestion pipeline errors, license/quota exhaustion, disk-full on collectors, and Windows Event ID 1104 (security log full) / 1102 (audit log cleared). (3.3.4, 3.3.8)
- Document the response: who is notified, how fast, and what the fallback is (local buffering, agent restart, out-of-band capture) while the pipeline is down. (3.3.4)

Audit Reduction and Report Generation (3.3.6)

- Maintain saved searches and dashboards that reduce raw volume to answerable questions: activity by a named user across all systems, all access to a given CUI share, all privileged actions in a date range. KQL, SPL, and Lucene/EQL saved queries all satisfy this. (3.3.6)
- Schedule recurring reports (weekly authentication summary, monthly privileged-activity report) and archive the generated output - the report artifacts double as 3.3.5 review evidence. (3.3.5, 3.3.6)

Protecting Audit Information and Tools (3.3.8, 3.3.9)

- Restrict SIEM roles: a small named set of audit administrators can modify data sources, retention, or rules; analysts get read/search; everyone else gets nothing. Export the role-membership list as evidence. (3.3.8, 3.3.9)
- Make stored logs tamper-resistant: immutable storage (Azure immutable blob policies, S3 Object Lock in compliance mode), Splunk index integrity controls, or restricted OS-level ACLs on log directories. (3.3.8)

- Separate duties: the administrators being audited should not be the only people who can alter or delete the audit trail. Forwarding to a SIEM that endpoint and server admins cannot administer achieves this structurally. (3.3.8, 3.3.9)
- Alert on the audit system's own audit trail: event-log clearing (1102), audit-policy changes (4719), and SIEM configuration changes should page someone. (3.3.8)

Tools for Extracting Structured Configuration Evidence

Wherever possible, capture evidence as **structured, text-based exports** - JSON, XML, CSV, or XCCDF - rather than screenshots. Machine-readable exports are timestamped, show the full setting, and can be ingested directly by a compliance platform.

Windows Audit Policy and Event Logs

- `auditpol /get /category:* /r` - the effective advanced audit policy as CSV; the single most direct 3.3.1 artifact for Windows hosts. (3.3.1)
- `Get-GPOReport -ReportType Xml` - the audit-policy GPO (and who can edit it) as XML. (3.3.1, 3.3.9)
- `wevtutil gl Security` and `Get-WinEvent -ListLog` - log sizes, retention modes, and channel ACLs (the SDDL string shows who can read or clear the log) as text. (3.3.8)
- **Sysmon** - `sysmon -c` dumps the active configuration; keep the deployed XML config under version control. (3.3.1)
- `auditctl -l` and `/etc/audit/rules.d/` exports on Linux - the active auditd ruleset as text. (3.3.1)

Time Synchronization

- `w32tm /query /configuration` and `w32tm /query /status /verbose` - source, stratum, and last-sync data as text; run on the PDC emulator and a sample member. (3.3.7)
- `chronyc sources -v` / `ntpq -p` - peer list and offsets on Linux; `show ntp status` (Cisco) or equivalents on network devices. (3.3.7)

SIEM Configuration Exports

- **Microsoft Sentinel** - export analytics rules, data connectors, and workspace retention via the Azure REST API / `az sentinel` / ARM templates as JSON; the "Export" action on analytics rules yields deployable JSON. (3.3.1, 3.3.4, 3.3.5)
- **Splunk** - `savedsearches.conf`, `indexes.conf` (retention via `frozenTimePeriodInSecs`), and `authorize.conf` (roles) are text files by design; the REST API (`/services/saved/searches`) returns JSON/XML. (3.3.5, 3.3.6, 3.3.8, 3.3.9)

- **Elastic** - detection rules export as NDJSON from Kibana; ILM policies and index settings via the REST API as JSON. (3.3.1, 3.3.5)
- **Wazuh** - rules and decoders are XML on disk; the Wazuh API returns agent status (for 3.3.4 coverage evidence) and configuration as JSON. (3.3.4, 3.3.5)

Cloud Audit Trails and Identity Logs

- **Microsoft Graph / Entra ID** - sign-in and directory audit logs, and diagnostic-settings exports showing where logs are routed, as JSON. (3.3.1, 3.3.2)
- **M365 Unified Audit Log** - `Search-UnifiedAuditLog` results as CSV/JSON; audit-retention policy settings from the Purview portal or `Get-UnifiedAuditLogRetentionPolicy`. (3.3.1)
- **AWS** - `aws cloudtrail describe-trails / get-event-selectors`, plus S3 Object Lock configuration (`aws s3api get-object-lock-configuration`) as JSON. (3.3.1, 3.3.8)

Review-Process Evidence

- **Ticketing exports** (Jira, ServiceNow) - alert-triage tickets with dispositions as CSV/JSON; the strongest 3.3.5 process evidence available. (3.3.3, 3.3.5)
- **Scheduled report archives** - the SIEM's emailed/saved report output, retained in the evidence store with dates. (3.3.5, 3.3.6)

SCAP & Benchmark Scanners (authoritative, structured)

- **DISA SCAP Compliance Checker (SCC)** with STIG benchmarks - audit-policy compliance results as XCCDF/OVAL/ARF XML. (3.3.1, *host-level*)
- **OpenSCAP** (`oscap`) for Linux hosts - validates auditd configuration against benchmark content, results as XCCDF/ARF XML. (3.3.1)

OSCAL & Compliance Automation (the structured-format endgame)

- **OSCAL** (NIST Open Security Controls Assessment Language) - represent your SSP, components, and assessment results as JSON/XML/YAML. (*all AU*)
- **IBM compliance-trestle (Trestle)** - author and validate OSCAL artifacts programmatically. (*all AU*)

Practical tip: for every export, record what was run, on which system, and when. A traceable, dated artifact is worth far more than an undated screenshot.

Conclusion

The Audit and Accountability family is a pipeline with a human at the end: enforce unique identities, turn on meaningful audit policy at every source, forward everything to one SIEM

synced to one clock, retain it for a defined period in storage no one can quietly alter, and - the part most often missed - review it on a schedule and keep the records that prove you did. Collection without documented review is the family's most common assessment failure, and the cheapest one to fix.

The July 2026 suspension of CMMC Phase 2 paused the third-party certification milestone, not the underlying obligation: NIST SP 800-171, DFARS 252.204-7012, and the Level 2 self-assessment remain fully in force. Implementing this family well is still required today.

Glossary of Acronyms

ACL	Access Control List
ARF	Asset Reporting Format (SCAP results format)
ARM	Azure Resource Manager
CMMC	Cybersecurity Maturity Model Certification
CUI	Controlled Unclassified Information
DFARS	Defense Federal Acquisition Regulation Supplement
DIB	Defense Industrial Base
EQL	Event Query Language (Elastic)
FIPS	Federal Information Processing Standard
GCC	Government Community Cloud
GPO	Group Policy Object
ILM	Index Lifecycle Management (Elastic)
KQL	Kusto Query Language
MDM	Mobile Device Management
MDR	Managed Detection and Response
MSSP	Managed Security Service Provider
NIST	National Institute of Standards and Technology
NTP	Network Time Protocol
OSCAL	Open Security Controls Assessment Language
PAM	Privileged Access Management

PDC	Primary Domain Controller (emulator FSMO role)
POA&M	Plan of Action and Milestones
RBAC	Role-Based Access Control
SCAP	Security Content Automation Protocol
SDDL	Security Descriptor Definition Language
SIEM	Security Information and Event Management
SOC	Security Operations Center
SPL	Search Processing Language (Splunk)
SPRS	Supplier Performance Risk System
SSP	System Security Plan
STIG	Security Technical Implementation Guide
UTC	Coordinated Universal Time
VPN	Virtual Private Network
WORM	Write Once, Read Many
XCCDF	Extensible Configuration Checklist Description Format
XDR	Extended Detection and Response

About Methodical Security

Methodical Security provides resources and tooling to support Defense Industrial Base organizations through CMMC / NIST SP 800-171 assessments. Its platform, **Certalo**, works at the determination-statement level: it maps your existing documentation to each objective, flags where evidence is thin, and compresses the path to a submission-ready SSP, Assessment Report, and SPRS package. The result turns a one-time compliance scramble into a repeatable process — protecting current revenue and opening new contract eligibility.

Prepared by Methodical Security for informational purposes. Not legal advice - confirm obligations against your contract clauses and the DoD CMMC Program Office. · methodicalsecurity.com/resources